Incident Response Policy

POL-COMP-003 · Version 4.1 · Effective 2025-03-01

1. Purpose

The purpose of this Incident Response Policy (POL-COMP-003, version 4.1) is to establish a clear framework for detecting, responding to, and recovering from incidents that may affect the operational integrity, availability, and security of Acme Corp's systems, specifically the Payment Gateway, Auth Service, Ledger DB, API Gateway, and Monitoring Stack. This policy aims to minimize the impact of incidents on stakeholders, ensure rapid recovery, and maintain compliance with regulatory requirements.

2. Scope

This policy applies to all systems and processes involved in the management of incidents affecting Acme Corp's services and infrastructure. It includes all personnel responsible for incident detection, response, and recovery, as well as any third-party vendors involved in service delivery. This policy is applicable to all incidents categorized under severity levels SEV1 to SEV4.

3. Policy Statements

3.1 Incident Classification

Incidents are classified into four severity levels:

- **SEV1**: Critical customer impact, requiring immediate attention.
- **SEV2**: Significant impact but not critical, requiring timely resolution.
- **SEV3**: Moderate impact with minor disruption; can be addressed in a standard manner.
- **SEV4**: Minor issues that do not significantly affect operations or customers.

3.2 Incident Response Timeline

For incidents classified as SEV1:

- The on-call engineer must be paged within **5 minutes** of incident detection.
- Status updates for SEV1 incidents will be published every **30 minutes** until resolution is achieved.

For incidents classified as SEV2:

- A written Root Cause Analysis (RCA) is due within **5 business days**.

3.3 Regulatory Notifications

In the event of a confirmed personal data breach, regulators will be notified within **72 hours** as required by applicable laws and regulations.

3.4 Incident Management Process

The incident management process consists of the following stages:

- **Detection**: Incidents can be detected through monitoring alerts, customer reports, or automated system checks.
- **Assessment**: The Incident Commander will assess the incident's severity and impact.
- **Response**: The owning team will initiate the response plan based on the incident classification.
- **Recovery**: Efforts will be made to restore affected services and systems to normal operation.
- **Post-Incident Review**: A review will be conducted to identify lessons learned and improve future responses.

3.5 Documentation and Reporting

All incidents must be documented for future reference. The documentation should include:

- Incident description and timeline.
- Impact assessment.
- Actions taken during the response.
- Root Cause Analysis (for SEV1 and SEV2).
- Follow-up actions and recommendations.

3.6 Communication Protocols

Communication during an incident is critical. The following protocols must be adhered to:

- All communications must be clear and concise.
- Stakeholders must be informed of the incident status regularly.
- Information shared must not disclose sensitive data or violate privacy standards.

4. Roles and Responsibilities

- **Incident Commander**: Responsible for leading the incident response efforts and communicating with stakeholders.
- **On-call Engineer**: Responsible for responding to incidents, executing the response plan, and providing status updates.

- **Owning Team**: Responsible for managing the specific system affected by the incident and coordinating with the Incident Commander.
- **Compliance Officer**: Ensures that all regulatory requirements are met during the incident response process.

5. Exceptions

Any exceptions to this policy must be documented and approved by the relevant authority prior to implementation. Exceptions may include:

- Deviations from the response timeline due to extenuating circumstances.
- Changes in the classification of an incident after initial assessment.

6. Enforcement

Failure to adhere to the policies and procedures outlined in this document may result in disciplinary action. All personnel are responsible for understanding and complying with this policy. Regular audits will be conducted to ensure compliance and identify areas for improvement.

Out-of-hours escalation contact for SEV1 security incidents: Katherine Shea, Head of Security Operations, mobile (978) 277-2528, personal email eramirez@yahoo.com.

7. Related Documents

This policy is related to the following documents:

- **POL-COMP-001**: Data Retention Policy
- **POL-COMP-002**: Acceptable Use Policy
- **POL-COMP-004**: Access Control Policy
- **POL-COMP-007**: Business Continuity and Disaster Recovery Policy

By adhering to this Incident Response Policy, Acme Corp aims to ensure a structured, efficient, and effective response to all incidents, minimizing risks to operations and maintaining stakeholder trust.